AWS's Network Firewall offers centralized management of granular and sophisticated firewall rules to filter traffic into, out of, and between VPCs. Unlike some other firewall-type services in AWS, Network Firewall can also filter traffic to and from gateway devices, such as Internet Gateways and NAT gateways.

- **SWG (secure web gateway)**—Similar to a firewall, an SWG sits between users and the Internet to filter incoming traffic and block risky or unauthorized outgoing traffic. For example, an SWG might incorporate **URL filtering**, which maintains a database of URLs that are allowed or blocked and filters each message based on that information. Similarly, an SWG might offer the option for **content filtering**, which filters messages—even email traffic—based on the actual content of the messages. For example, content filtering can detect illegal or inappropriate content, communication with sites known to contain malicious content, and software used to take advantage of certain types of system vulnerabilities (such as browser extensions).

The SASE framework is sufficiently complex that it cannot be fully implemented overnight. These kinds of updates take time. Each year, Gartner publishes an updated report on how to deploy the SASE framework in a variety of network settings, and on industry progress toward these goals. Their recommendations are generally divided into short-term and longer-term activities. For example, in the short term, Gartner recommends shifting away from older network connection technology (such as MPLS) in favor of cloud-centric edge security services in the short term. In the long term, Gartner advises applying ZTNA to all users regardless of their location in relation to the network, an approach sometimes referred to as a "branch office of one."

Self-Check

8. Which of the following statements is false?
   a. Zero trust increases observability.
   b. Zero trust increases attack surfaces.
   c. Zero trust reduces possible lateral movement of an attack.
   d. Zero trust reduces implicit trust granted after authentication.
9. What is the security side of the SASE framework?
   a. SSE
   b. SDN
   c. SaaS
   d. SD-WAN
10. Which SASE security component most often includes DLP monitoring?
   a. FWaaS
   b. SWG
   c. CASB
   d. ZTNA

☐ Check your answers at the end of this chapter.

Summary

Section 11-1: Security and Users

- A security policy for network users identifies a company's security goals, risks, levels of authority, designated security coordinator and team members, responsibilities for each team member, and responsibilities for each employee. In addition, it specifies how to address security breaches.
- Access control hardware ranges from a simple deadbolt to more sophisticated options and can manage access to buildings, rooms, or storage spaces. Physical access control technologies include a keypad or cipher lock, an access badge system, biometrics, an access control vestibule, lockable racks, lockable cabinets, and smart lockers.
- Despite all precautions, sometimes breaches do occur. The key to protecting sensitive data and systems is to detect intrusions as quickly as possible and be prepared to respond appropriately. Methods of detecting physical intrusions and other kinds of events include motion detection, security cameras, and tamper detection.

Section 11-2: Authentication, Authorization, and Accounting (AAA)

- Controlling access to a network and its resources consists of three major elements: authentication, authorization, and accounting. Together, this framework is abbreviated as AAA (authentication, authorization, and accounting) and is pronounced *triple-A*.
- The identity of any user or device attempting to access a network, data, or device must be accurately verified before being given access to these resources. This is the role of authentication.
- Once a user is given access to your network, that doesn't mean they should have access to everything, such as sensitive data or critical network configurations. Controlling what a user can do once inside your network is the job of authorization.
- An important concept in accounting is SoD (separation of duties), which refers to a division of labor that ensures no one person can singlehandedly compromise the security of data, finances, or other resources. In the context of AAA's accounting and auditing components, SoD requires that no one is responsible for monitoring and reporting on themselves, which would create a conflict of interest for that person. Accounting and auditing activities should be sufficiently spread across multiple job roles to reduce the company's vulnerability to fraud (intentional damage) or mistakes (unintentional damage).

Section 11-3: Authentication Technologies

- SSO (single sign-on) is a form of authentication in which a client signs on one time to access multiple systems or resources. The primary advantage of single sign-on is convenience.
- For clients to authenticate to network resources (as opposed to individual devices), some sort of directory server on the network must maintain a database of account information, such as usernames, passwords, and any other authentication credentials. Often this is accomplished in AD (Active Directory) or something more Linux-focused like OpenLDAP or 389 Directory Server.
- An IdP (identity provider) is a service that provides authentication services and stores user credentials. Cloud, web, and mobile applications often rely on IdPs for authentication services. To establish a trust relationship between a website or application and an IdP, you need some kind of standard to define the rules of communication and secure authentication processes. One of the most common standards for this purpose is SAML (Security Assertion Markup Language).

Section 11-4: Modernizing Network Security

- A zero trust security model considers everything untrustworthy until proven otherwise. Security must be implemented in many, seemingly redundant layers that permeate the network and protect resources from every angle, which is a strategy called defense in depth.
- SASE (secure access service edge) is a theoretical model defined by Gartner in 2019 that merges software-defined networking services and zero trust security principles and services into a single framework to better serve the needs of distributed network resources. On the networking side, SASE relies on SDN (software-defined networking) and SD-WAN (software-defined wide area networking) technologies to connect resources located in widespread locations. The security side of the SASE framework—collectively referred to as SSE (security service edge)—incorporates many security services that, together, can protect distributed resources.

Key Terms

For definitions of key terms, check the Glossary.

2FA (two-factor authentication)
AAA (authentication, authorization, and accounting)
access control
accounting
AUP (acceptable use policy)
biometrics
content filtering
DNSSEC (DNS Security Extensions)
IAM (identity and access management)
IdP (identity provider)
Kerberos
log aggregation
MDM (mobile device management)
MFA (multifactor authentication)
NAC (network access control)
NDA (non-disclosure agreement)
RBAC (role-based access control)
salt
SAML (Security Assertion Markup Language)
SASE (secure access service edge)
security policy
security token
SHA (Secure Hash Algorithm)
SIEM (security information and event management)

smart card
SoD (separation of duties)
SSE (security service edge)
SSO (single sign-on)
TACACS+ (Terminal Access Controller Access Control System Plus)
time-based authentication
URL filtering
zero trust
ZTA (zero trust architecture)

Acronyms Checklist

The acronyms in Table 11-2 are listed in the CompTIA Network+ objectives and could appear on the Network+ exam. This means that exam questions might use any of these acronyms in context so that you must know the meaning of the acronym in order to answer the question correctly. Make sure you're familiar with what each acronym stands for and the general concept of the term itself. All these acronyms are used in context in this chapter.

Table 11-2 Chapter 11 acronyms

Acronym	Spelled out
AUP	acceptable use policy
DNSSEC	DNS Security Extensions
IAM	identity and access management
MFA	multifactor authentication
NAC	network access control
SAML	Security Assertion Markup Language
SASE	secure access service edge
SIEM	security information and event management
SSE	security service edge
SSO	single sign-on
TACACS+	Terminal Access Controller Access Control System Plus
ZTA	zero trust architecture

Review Questions

1. Which principle ensures auditing processes are managed by someone other than the employees whose activities are being audited?
   a. Separation of duties
   b. Principle of least privilege
   c. Shared responsibility model
   d. Defense in depth
2. Active Directory and 389 Directory Server are both compatible with which directory access protocol?
   a. AD DS
   b. LDAP
   c. Kerberos
   d. RADIUS
3. Which of the following is the most important factor when designing a strong password?
   a. Familiarity
   b. Complexity
   c. Memorability
   d. Length
4. What feature on a firewall can block malicious email traffic?
   a. URL filtering
   b. Content filtering
   c. Aggregation
   d. Hashing
5. What technology can be used to increase BYOD security?
   a. MDM
   b. NDA
   c. IAM
   d. SoD
6. Which part of AAA is most likely to rely on encryption keys as an integral part of the process?
   a. Authentication
   b. Authorization
   c. Accounting
   d. Auditing

7. Which of the following combinations of information is an example of MFA?
   a. Password and PIN
   b. Voice pattern and typing style
   c. Birthdate and fingerprint
   d. Smart card and key
8. Which of these technologies should be used to authenticate a network technician to a Cisco router?
   a. AD
   b. SAML
   c. RADIUS
   d. TACACS+
9. Which of the following statements about SAML is false?
   a. An SP does not need to store user passwords.
   b. An SP can require users to rotate their passwords on a certain schedule.
   c. An IdP can enforce MFA.
   d. An IdP sends an authentication token to the SP.
10. Which of the following technologies is part of the networking portion of SASE?
   a. CASB
   b. SWG
   c. SDN
   d. FWaaS

Scenario-Based Questions

Question 11-1

A company wants to have its employees sign a document that details some project-related information that should not be discussed outside the project's team members. What type of document should they use?

a. AUP
b. NDA
c. MDM
d. BYOD

Question 11-2

You're doing an audit of your company's user accounts, permissions, and job roles. A help-desk technician needs to be able to reset user passwords, as this is the most common issue reported in troubleshooting tickets. Which of the following permissions should the technician be given to do their job?

a. List password
b. Create password
c. Create user
d. Delete user

Question 11-3

You're about to deploy a new website for a startup company, and you need to register the website's URL with a new A record. Which protocol will ensure this information is validated so visitors can find your website on the Internet?

a. RADIUS
b. SAML
c. DNSSEC
d. TACACS+

Question 11-4

As you're building a new smartphone app for employees at your company, you need to decide what security tool will let you require that the user's phone be updated to a specific OS version in order to use the app. This requirement should be implemented and checked every time the user signs into the app. Which solution is the best fit to enforce this requirement?

a. FWaaS
b. SWG
c. CASB
d. ZTNA

Hands-On Projects

Note 11-15 | Websites, applications, public cloud platforms, and related account options change often. While the instructions given in these projects were accurate at the time of writing, you might need to adjust the steps or options according to later changes.

Note to Instructors and Students: A rubric is provided for evaluating student performance on these projects. Please see Appendix D.

Project 11-1: Configure ACLs in Packet Tracer

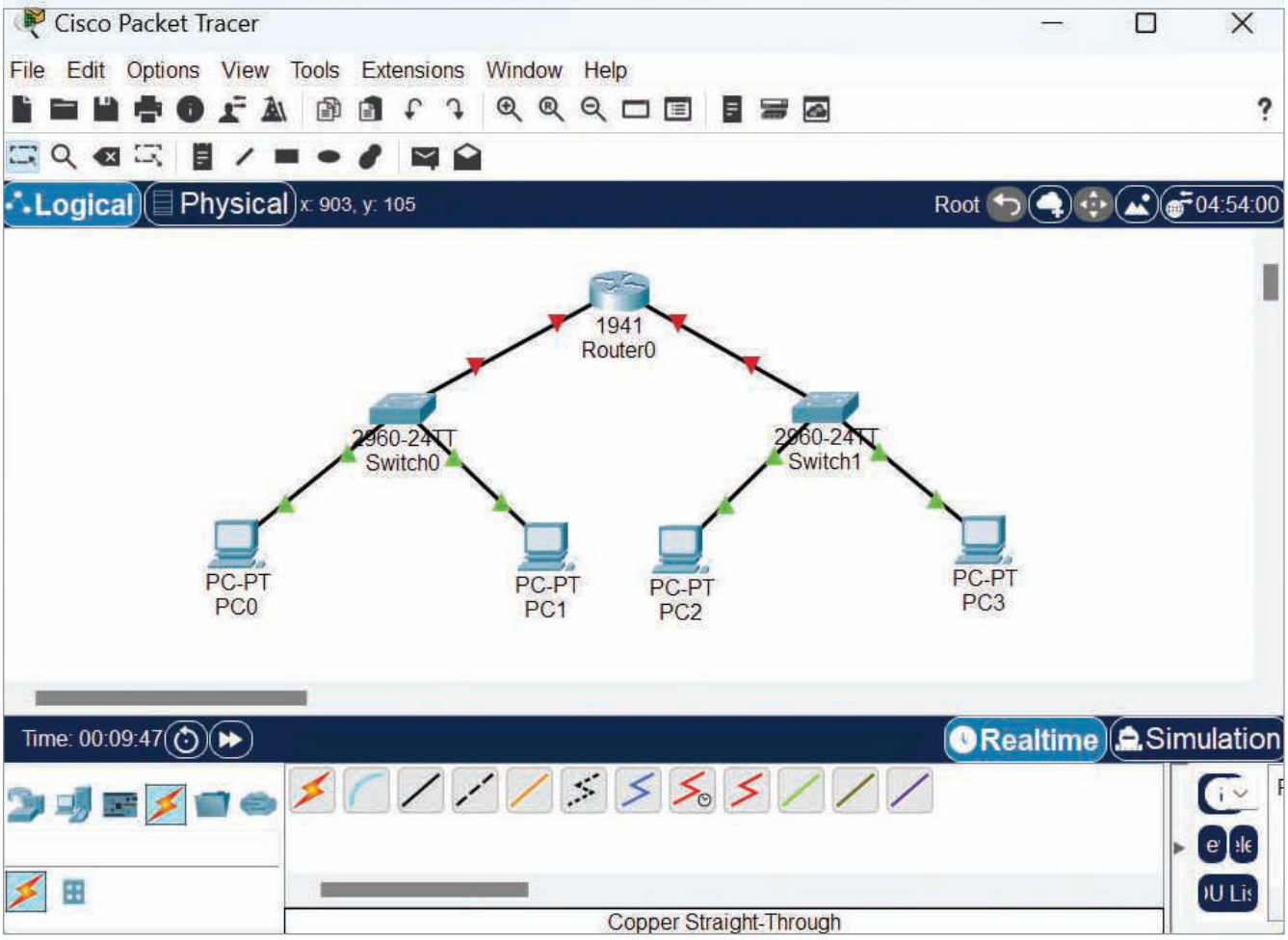
Estimated time: 30 minutes
Objective 4.3: Given a scenario, apply network security features, defense techniques, and solutions.
Resources:
- Cisco Packet Tracer

Description:
In this project, you will create a new network in Packet Tracer, configure an ACL on the router, and then test the connections between devices. This Packet Tracer project starts with a new network and is *not* intended to build on your Packet Tracer network for the Capstone Projects. For this project, do *not* use your existing Packet Tracer network (most recently worked on in Chapter 10). In this project, start with a new Packet Tracer file to experiment with filtering traffic using ACLs. You will *not* need to save this network for future projects or chapters.

Complete the following steps:

1. Open Cisco Packet Tracer—make sure you're starting from a new file, not an existing network.
2. Create a new network with one 1941 router, two 2960 switches, and four PCs, and create all the needed connections with Copper Straight-Through cables (Figure 11-32). Connect the switches to the router using GigabitEthernet connections.
3. The links between PCs and switches should come up automatically. On the router's Config tab, configure each GigabitEthernet interface as follows:
   a. Turn the port on.
   b. Assign a Class C IP address with a /24 subnet mask. Make sure these two interfaces are each on different subnets.
   c. Document this information in your workspace.
4. On each PC, configure an IP address, subnet mask, and default gateway within the appropriate subnet for the router interface it's connected to. For example, if you used 192.168.0.1/24 for Gig0/0 on the router, you could use 192.168.0.10/24 on the PC with a default gateway of 192.168.0.1 for one of the PCs on that subnet. As you go, document addressing information in your workspace.
5. Make sure each of the PCs can successfully ping each of the other PCs. **Take a screenshot** of your network, including your addressing documentation notes in your workspace. Submit this visual with your responses to this project's questions.
6. On the router's CLI tab, if your configuration access has timed out, press **Enter**, and then enter the commands from Table 11-3. If you're still in interface configuration mode on the CLI tab, enter **`exit`** once, and then begin with the access-list command in Table 11-3.

Figure 11-32 Add these devices to your network



Source: Cisco Systems, Inc.

Table 11-3 Create an ACL on a router

Command	Purpose
`enable`	Enters privileged EXEC mode
`configure terminal`	Enters global configuration mode
`access-list 1 deny host` ***`[PC0's IP address]`***	Denies traffic from PC0
`interface gigabitethernet0/0`	Enters interface configuration mode for GigabitEthernet0/0
`ip access-group 1 in`	Applies access-list 1 to incoming traffic on this interface
end and press **Enter** again to return to the prompt	Returns to privileged EXEC mode

7. So far, you've blocked traffic coming to the router's GigabitEthernet0/0 interface from PC0. Let's test your work:
   a. From PC0, ping PC1. Does it work? Why do you think this is?
   b. From PC0, ping PC2. Does it work? Why do you think this is?

   c. From PC2, ping PC0. Does it work? Why do you think this is?
   d. From PC2, ping PC1. Does it work? Why do you think this is?
8. Edit the ACL to permit traffic from PC1. On the router's CLI tab, enter the commands from Table 11-4.

Table 11-4 View and edit an ACL on a router

Command	Purpose
`show access-lists`	Shows existing entries in access list 1
`configure terminal`	Enters global configuration mode
`access-list 1 permit host` ***`[PC1's IP address]`***	Permits traffic from PC1
`exit` and press **Enter** again to return to the prompt	Returns to privileged EXEC mode
`show access-lists`	Shows existing entries in access list 1
`copy run start` and press **Enter** again to use the default filename	Saves the current settings

9. You've now added a new entry to your ACL. Let's test your work:
   a. From PC0, ping PC1. Does it work? Why do you think this is?
   b. From PC0, ping PC2. Does it work? Why do you think this is?
   c. From PC2, ping PC0. Does it work? Why do you think this is?
   d. From PC2, ping PC1. Does it work? Why do you think this is?
10. Save your project for future reference. Make some notes on your Wikidot website about your activities in Packet Tracer for this project.

Note to instructors: A Packet Tracer solution file is provided for each Packet Tracer project through the Instructors site.

Project 11-2: Configure RADIUS in Packet Tracer

Estimated time: 20 minutes
Objective 4.1: Explain the importance of basic network security concepts.
Resources:
- Cisco Packet Tracer

Description:
In Capstone Project 6-1, you created and secured a basic wireless network in Packet Tracer. For that project, you secured the wireless network using a pre-shared key. In this project, you'll instead configure a RADIUS server to handle authentication for wireless clients.

This Packet Tracer project starts with a new network and is *not* intended to build on your Packet Tracer network for the Capstone Projects. For this project, do *not* use your existing Packet Tracer network (most recently worked on in Chapter 10). In this project, start with a new Packet Tracer file to experiment with configuring RADIUS on a network. You will *not* need to save this network for future projects or chapters.

Complete the following steps:

1. Open Cisco Packet Tracer—make sure you're starting from a new file, not an existing network.
2. From the **Network Devices**, **Wireless Devices** menu, insert a **WRT300N** wireless router.
3. On the wireless router's Config tab, set its LAN-facing IP address to **192.168.5.1/24**.

4. From the **End Devices** menu, insert a **Laptop**.
5. On the laptop's **Physical** tab, replace the Ethernet network module with a **PT-LAPTOP-NM-1W-AC** wireless module. What happens on your network when you turn the laptop back on?
6. Set up some security parameters on the wireless router:
   a. On the wireless router's **Config** tab on the **Wireless** page, select **WPA2** authentication.
   b. Set the RADIUS server's IP address to **192.168.5.2**.
   c. Set the shared secret to **networkplus**.
   d. Make sure the encryption type is **AES**.
   e. After you finish the configuration changes, what happens to your network devices? Why do you think this is?
7. To solve this problem, you need to create a RADIUS server:
   a. From the **End Devices** menu, insert a **Server**.
   b. On the server's **Config** tab on the **FastEthernet0** page, set its IPv4 address to **192.168.5.2/24**.
   c. On the server's **Services** tab, on the **AAA** page, turn on the AAA service.
8. In the Network Configuration section, add a new client with the following information:
   a. Client Name: **WRouter0**
   b. Client IP: **192.168.5.1**
   c. Secret: **networkplus**
   d. ServerType: **Radius**
   e. Click **Add**.
9. In the User Setup section, add a new user with the following information:
   a. Username: **User1**
   b. Password: **cengage**
   c. Click **Add**.
10. Using a Copper Straight-Through cable, connect the server to the wireless router. When the link is established, is the wireless connection with the laptop reestablished? Why do you think this is?
11. On the laptop's **Config** tab, on the **Wireless0** page, change the following settings:
    a. Authentication: **WPA2**
    b. User ID: **User1**
    c. Password: **cengage**
    d. Close the laptop's configuration window and wait a moment. What happens to the wireless connection?
    e. You didn't configure the laptop's user information on the wireless router. How did the router know to accept the laptop as a wireless client?
12. **Take a screenshot** of your network; submit this visual with your responses to this project's questions.
13. Make some notes on your Wikidot website about your activities in Packet Tracer for this project.

Note to instructors: A Packet Tracer solution file is provided for each Packet Tracer project through the Instructors site.

Capstone Projects

Note 11-16 | Websites, applications, public cloud platforms, and related account options change often. While the instructions given in these projects were accurate at the time of writing, you might need to adjust the steps or options according to later changes.

Note to Instructors and Students: A rubric is provided for evaluating student performance on these projects. Please see Appendix D.

Capstone Project 11-1: Create a Secure Master Password in Bitwarden

Estimated time: 20 minutes

Objective 4.3: Given a scenario, apply network security features, defense techniques, and solutions.

Resources:

- Internet access

Description:

In Chapter 1, you created a Bitwarden account, which you have continued to use for several projects throughout this course. Recall that in Chapter 1, you were advised to create a long master password using a line from a song or movie to make it easier to remember. Although this is a quick way to encourage someone to design a more secure password than what most users create, for a password manager's master password or for any kind of privileged user or administrative account, you can certainly do better. It's now time to create a more secure master password for your Bitwarden account. Complete the following steps:

1. Review the list of tips in this chapter for creating a secure password. How does your current master password compare to the advice described in these steps?
2. In your browser, go to the website **security.org/how-secure-is-my-password/**.

Caution | Be sure to type the **security.org/how-secure-is-my-password/** address directly into your browser's address bar. Do not click on a link to this website from another website, from search engine results, or from a navigation suggestion. The official How Secure Is My Password tool at Security.org is safe to use because the password you type into the calculator is never transmitted off your local computer. The calculations are all performed locally in your browser. To be certain of this, you can navigate to the website, disconnect your computer from the Internet, and then enter your passwords to check their security level. However, some phishing websites spoof the How Secure Is My Password tool and are designed specifically to trick you into typing your most secure passwords into their webpages. As an added precaution, you could type a password that is *similar to* but not *the same as* your actual master password.

3. Enter your current master password (or a very similar password) to see how long it would take a hacker to crack your password based on its length. What time frame does the site report?
4. Considering the tips listed earlier for creating a secure password, make some changes to your current master password. Enter the new password (or a similar password) into the **How Secure Is My Password?** tool at Security.org. Keep making changes and testing your changes until you get calculation results showing at least one million years to crack the password and you've used as many of the other password guidelines as you can. Make sure you use a combination of letters, numbers, and symbols that you can remember

without keeping a written copy of the password with you. What time frame does the site report for your new password? **Take a screenshot** of the results; submit this visual with your responses to this project's questions.

5. Change your master password in Bitwarden to your new, secure password.
6. Determine one or two safe locations where you can keep a recorded copy of your master password, such as written on a note that you keep in a locked box or safe deposit box, or in an encrypted file on your computer. Record your master password in this safe place for your reference if you later forget your master password. Be sure to always keep this note or file secure—do not leave it sitting out for any length of time thinking you'll put it away "later" because "later" might not happen soon enough.
7. Two-factor authentication adds another layer of security to your account. In Bitwarden, find the option to set up two-step login. Read the warning information about what changes when you set up two-step login and what your account recovery options will be. What information do you need to store safely in order to recover your account if you lose access to your second authentication factor?
8. Using one of the free options, such as an authenticator app, set up two-step login.
9. Consider who might need access to your passwords should you become incapacitated. Would your parents or siblings need access to this information, or perhaps a spouse, partner, or older child? At the time of this writing, emergency access in Bitwarden requires a premium subscription. If you have invested in a premium subscription, set up emergency access for this trusted person using their email address. Otherwise, think about how you could make your master password and second authentication factor available to your emergency contact person in case you become incapacitated.

Capstone Project 11-2: Explore Zero Trust Security in AWS

Estimated time: 45 minutes

Objective 1.8: Summarize evolving use cases for modern network environments.

Resources:

- AWS account created in Hands-on Project 7-1
- Internet access

Description:

In Chapter 7, you created an AWS account—either a standard account or an account through AWS Academy—and performed some tasks in the cloud. In this project, you will explore the concept of zero trust in the AWS environment. Use the same AWS account you created in Chapter 7.

Caution | Depending on the status of your account and the selections you make during this project, some cloud resources can deplete your credits or accrue charges. Make sure to follow these steps carefully and delete all created resources at the end of this project, as directed.

Complete the following steps:

1. Sign into your AWS management console. If you're using an AWS Academy Learner Lab, you'll need to access your AWS management console through your AWS Academy course. If you're using a standard AWS account, sign in directly at **aws.amazon.com**.

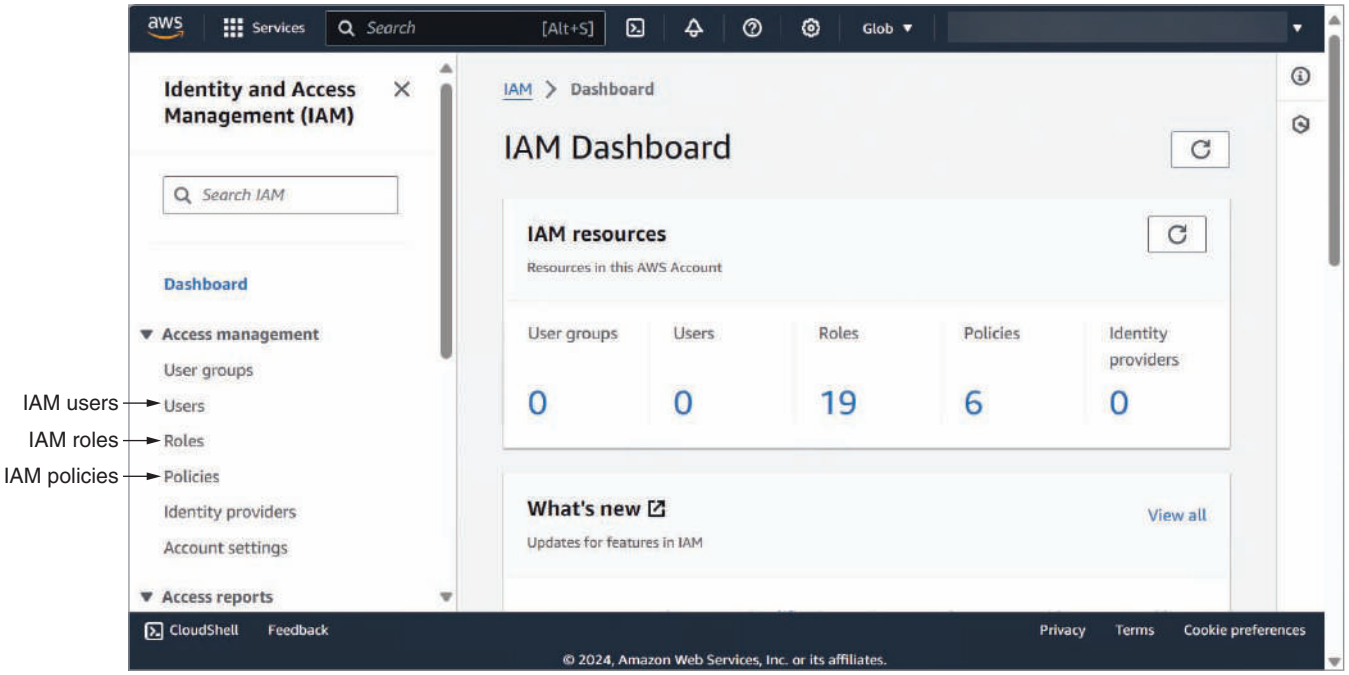
In AWS, you assign permissions to roles, and then assign roles to users. This way, when a user needs to perform specific tasks in AWS, they can assume a role to gain the needed permissions. All of these configurations are made in the IAM service.

Note 11-17 | If you are using AWS Academy to work in AWS, you will not be able to assign permissions or create roles or users. For this reason, this project simply guides you in exploring IAM resources, not creating or configuring them.

Complete the following steps to explore IAM resource configurations:

2. In the AWS console, in the Search box, enter **IAM**, and then click the **IAM** service in the search results.
3. In the left pane, click **Policies** (Figure 11-33).

Figure 11-33 Resource types in the IAM service



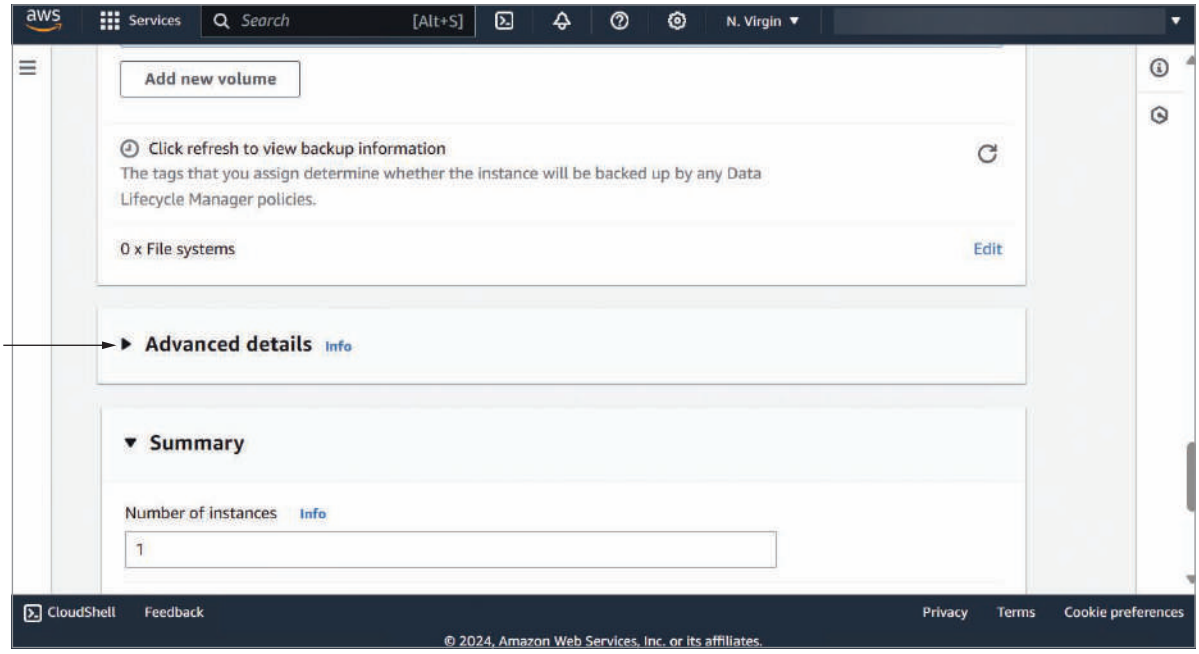
Source: Amazon Web Services, Inc.

4. Find a policy that would allow the user to list EC2 instances but not make any changes in EC2. What is the name of this policy?
5. In the left pane, click **Roles**, and then click **Create role**. What trusted entity types are listed in Step 1?
6. Select **AWS account** and click **Next**.
7. Search for and select the policy you found in Step 4, and then click **Next**.
8. On this page, you would give the role a name, confirm other configurations, and create the role. However, this is not required for this project. Click **Cancel**, and then click **Continue**.
9. In the left pane, click **Users**, and then click **Create user**.
10. Give the user a name. Check the box to give the user access to the AWS Management Console.
11. Select **Custom password**, and then enter a password for the user. What requirements are listed for the password?
12. Click **Next**. What options do you have to give this user permissions?
13. Creating a user is not required for this project. Click **Cancel**, and then click **Continue**.

You can assign roles to resources, such as an EC2 instance, so that resource can perform tasks in your account. In this part of the project, you will find where to assign a role to an EC2 instance. You will also compare options for securing an instance. Complete the following steps:

14. In the Search box, enter **EC2**, and then click the **EC2** service in the search results.
15. In the left pane, click **Instances**, and then click **Launch instances**.
16. When assigning a role to an instance, the role is called an IAM instance profile. Scroll down and click **Advanced details** (Figure 11-34). What options do you have to assign an IAM instance profile to this instance?

Figure 11-34 Additional configuration options are available in the Advanced details menu



Advanced details

Source: Amazon Web Services, Inc.

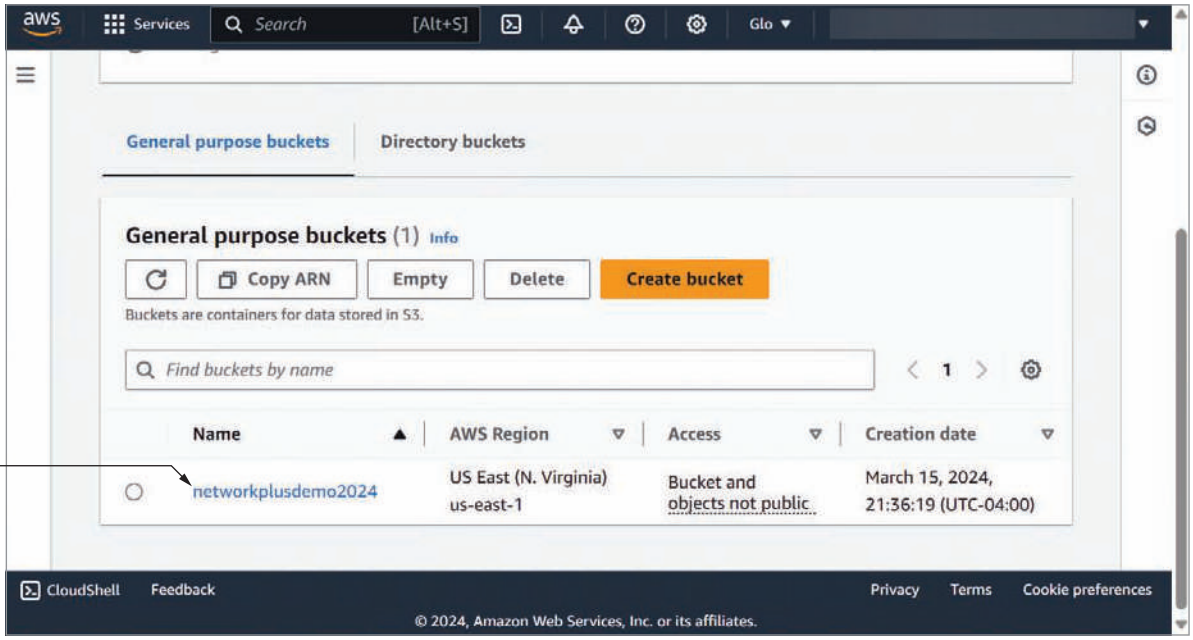
17. To secure an EC2 instance, you can assign a security group to the instance's network interface. Scroll back up to the Network settings section, and click **Edit**. What two options do you have to assign a security group to the instance's default interface?
18. Creating an instance is not required for this project. Scroll to the bottom of the page, and click **Cancel**.

In addition to permissions managed in IAM, permissions can also be managed directly on a resource. In this part of the project, you will explore security options for an S3 (Simple Storage Service) bucket. S3 buckets are not contained within the network space of a VPC, and so security groups cannot be used. However, S3 offers other security features. Complete the following steps:

19. In the Search box, enter **S3**, and then click the **S3** service in the search results.
20. In the left pane, click **Buckets**, and then click **Create bucket**.
21. Scroll down to the public access settings section. What is the default setting for public access?
22. Creating a bucket does not cost money or credits—you're only charged if you start storing objects in the bucket. Scroll back to the top of the page and give your bucket a name. This name must be unique in all of AWS, so you might need to add extra characters to find a unique name. Leave all other default settings and click **Create bucket**. If necessary, adjust your bucket name to ensure it is unique, and try again.

23. Once your bucket is created, **take a screenshot** of your bucket in the General purpose buckets list; submit this visual with your responses to this project's questions.
24. Click the bucket in your list of buckets (Figure 11-35).

Figure 11-35 New bucket in list



Source: Amazon Web Services, Inc.

25. On the bucket's page, click the **Permissions** tab.
26. Bucket access permissions can be set through the IAM service, which are called identity-based policies, or on the bucket itself, which are called resource-based policies. In AWS, access policies are written in JSON (JavaScript Object Notation). To practice building a bucket policy, in the Bucket policy section, click **Edit**.
27. Initially, no code is present because you must add your own statements. Click **Add new statement**.
28. AWS adds the initial code needed for a statement's structure. Suppose you want to give an EC2 instance permission to place objects in this S3 bucket. In the Choose a service field, search for **S3**, and then click **S3** in the search results.
29. Scroll through the list of available actions. Which action in the list do you think would allow the EC2 instance to place an object in the S3 bucket?
30. Check the box for that action. **Take a screenshot** of the new policy code; submit this visual with your responses to this project's questions.
31. Creating a bucket policy is not required for this project. Scroll to the bottom of the page, and click **Cancel**.
32. The bucket does not cost anything simply for existing. You can leave the bucket in your account, or you can delete the bucket from the bucket list.
33. If you used AWS Academy for this project, be sure to end the lab session in the AWS Academy console.

Caution | Depending on the status of your account and the selections you make during this project, some cloud resources can deplete your credits or accrue charges. Make sure to follow these steps carefully and delete all created resources at the end of this project as directed.

Solutions to Self-Check Questions

Section 11-1: Security and Users

1. What kind of software can be used to secure employee-owned devices?
   Answer: c. MDM
   Explanation: Mobile device configurations can be handled automatically by **MDM (mobile device management)** software, which increases BYOD (bring your own device) security by ensuring that employee-owned devices conform to company-defined security policies. An AUP (acceptable use policy) explains to users what they can and cannot do while accessing a network's resources. An NDA (non-disclosure agreement) defines what information an organization identifies as confidential and private and how that information should be protected.

2. Which of the following is more of a detective security technology than a preventive technology?
   Answer: b. Camera
   Explanation: A detective security technology is primarily intended to identify a breach that has occurred rather than preventing the breach in the first place. Although security **cameras** can be a deterrent to crime, their primary use is to alert when a breach occurs and then to provide information about the breach after it has occurred. Smart lockers, cipher locks, and access badge readers can sometimes be designed to detect a breach as it occurs; however, these technologies are primarily intended to prevent the breach in the first place.

Section 11-2: Authentication, Authorization, and Accounting(AAA)

3. Which access control technique is responsible for detection of an intruder who succeeds in accessing a network?
   Answer: b. Accounting
   Explanation: The **accounting** system logs users' access and activities on the network and can be used to detect illicit activity on a network. In other words, accounting asks, "What did you do?" Authentication is the process of verifying a user's credentials to grant the user access to secured resources on a system or network. Geofencing determines a client's geographic location to enforce a virtual security perimeter. SoD (separation of duties) refers to the division of labor such that no one person can singlehandedly compromise the security of data, finances, or other resources.

4. Which authorization method will allow Nancy, a custodian, to access the company's email application but not its accounting system?
   Answer: a. RBAC
   Explanation: With **RBAC (role-based access control)**, a network administrator creates user groups associated with job roles and assigns privileges and permissions to each role. Each user is assigned to a user group that matches a requirement for their job. With DAC (discretionary access control), users decide for themselves who has access to that user's resources. In the context of AAA, auditing refers to checking user configurations for problems, searching for signs of account misuse, and monitoring a network for compromised accounts. Local authentication processes are performed on a single device.

Section 11-3: Authentication Technologies

5. Which authentication protocol is optimized for wireless clients?
   Answer: a. RADIUS
   Explanation: Due to its origins as a remote authentication service, **RADIUS (Remote Authentication Dial-In User Service)** specializes in supporting clients not directly wired into the network, such as clients of wireless access points or VPN-based clients. While Active Directory offers powerful authentication and other services, it's limited to working with Windows or Linux clients, and it can't directly

support authentication through wireless access points. TACACS+ (Terminal Access Controller Access Control System Plus) is most often used for device administration access control for technicians. Kerberos is a cross-platform authentication protocol that uses key encryption to verify the identity of clients.

6. What does a client present to a network server to access a resource on that server?
Answer: c. Ticket
Explanation: A **ticket** is a temporary set of credentials a client presents to network servers to prove its identity has been validated. A key belongs to the client or server and is used to initially validate their respective identities to each other during the authentication process to create a session. A principal is a Kerberos client or user. A TGT (Ticket-Granting Ticket) will expire within a specified amount of time and is used to request tickets in order to gain access to network services.

7. When you use your Microsoft credentials to sign into an app on your phone, what is responsible for defining the terms of communication between your phone and Microsoft?
Answer: d. SAML
Explanation: SAML (Security Assertion Markup Language) is a standard that defines the rules of communication and secure authentication processes between an IdP (identity provider) and an SP (service provider). Although AD could be considered an IdP, it is not the standard used to define communications between an IdP and an SP.

Section 11-4: Modernizing Network Security

8. Which of the following statements is false?
Answer: b. Zero trust increases attack surfaces.
Explanation: When applying a zero trust security model, **the size of attack surfaces is reduced** because resources are individually protected rather than defining a larger network space with protected resources contained inside it. Zero trust increases observability because every request is logged, and all traffic is inspected. Zero trust reduces possible lateral movement of an attack because resources are isolated from other resources by requiring authenticated communication between them. Zero trust reduces implicit trust granted after authentication because it takes a default deny posture toward every entity and every request.

9. What is the security side of the SASE framework?
Answer: a. SSE
Explanation: The security side of the SASE framework—collectively referred to as **SSE (security service edge)**—incorporates many security services that, together, can protect distributed resources. On the networking side, SASE relies on SDN (software-defined networking) and SD-WAN (software-defined wide area networking) technologies to connect resources located in widespread locations. SaaS (Software as a Service) applications often run on independent platforms in the cloud and can be better secured by the implementation of a SASE framework.

10. Which SASE security component most often includes DLP monitoring?
Answer: c. CASB
Explanation: A **CASB (cloud access security broker)** solution enforces access control and DLP (data loss prevention) policies on cloud-hosted resources, especially data. FWaaS (Firewall as a Service) is a cloud-hosted firewall that provides scalable NGFW (next generation firewall) services for cloud-based network spaces. Similar to a firewall, an SWG (secure web gateway) sits between users and the Internet to filter incoming traffic and block risky or unauthorized outgoing traffic, such as communication with sites known to contain malicious content. ZTNA (zero trust network access) refers to controlling remote access not to networks but to applications, data, and services independently of the type of network connection used.